

ANKARA ÜNİVERSİTESİ

MÜHENDİSLİK FAKÜLTESİ

BİLGİSAYAR MÜHENDİSLİĞİ BÖLÜMÜ



BLM4522

AĞ TABANLI PARALEL DAĞITIM SİSTEMLERİ

PROJE 3

VERİTABANI GÜVENLİĞİ VE ERİŞİM KONTROLÜ

Zeliha Kıyak

22290878

 **GitHub : <https://github.com/zelihakiyak>**

VIDEO LİNKİ: <https://youtu.be/cZZzLs6qtb0>

1. Giriş

Bu projede AdventureWorks2022 veritabanı üzerinde kapsamlı güvenlik analizleri gerçekleştirilmiştir. Proje kapsamında SQL Server ve Windows Authentication modları karşılaştırılmış, rol bazlı erişim yönetimi uygulanmış, sütun bazlı veri şifreleme gerçekleştirilmiş, SQL Injection saldırısı simüle edilerek korunma yöntemi gösterilmiş ve SQL Server Audit ile kullanıcı aktiviteleri kayıt altına alınmıştır.

2. Kullanılan Araçlar ve Ortam

Projede Microsoft SQL Server 2022 Express Edition ve SQL Server Management Studio (SSMS) kullanılmıştır. Tüm güvenlik testleri AdventureWorks2022 örnek veritabanı üzerinde gerçekleştirilmiştir.

SQL Server Express Edition'da TDE (Transparent Data Encryption) desteklenmemektedir. Bu nedenle sütun bazlı şifreleme yöntemi uygulanmıştır. TDE Standard ve Enterprise Edition'da kullanılabilir.

3. Authentication Modları

SQL Server iki farklı authentication modunu desteklemektedir. Bu projede önce mevcut mod kontrol edilmiş, ardından Mixed Mode'a geçiş yapılmıştır.

	SQL Server Authentication	Windows Authentication
Kimlik Doğrulama	SQL Server yapar	Windows yapar
Şifre Yönetimi	SQL Server saklar	Windows saklar
Kullanım Yeri	Uygulama bağlantıları	Şirket içi kullanıcılar
Güvenlik Seviyesi	Orta	Yüksek

Mevcut authentication modunu kontrol eden sorgu çalıştırıldığında sonuç 1 döndü — SQL Server yalnızca Windows Authentication modundaydı. Projemiz için Mixed Mode'a geçiş yapıldı.

```
SELECT
    SERVERPROPERTY('IsIntegratedSecurityOnly') AS windows_only_mod,
    @@SERVERNAME AS sunucu_adi,
    SERVERPROPERTY('ProductVersion') AS versiyon;
```

4. Login Tipleri ve Eriřim Yönetimi

Mixed Mode aktif edildikten sonra SQL Server Authentication ile yeni bir login oluşturuldu. CHECK_POLICY parametresi řifre politikasını, CHECK_EXPIRATION ise řifre süre dolumunu zorunlu kılmaktadır.

```
USE master;

-- SQL Server Authentication ile login oluştur
CREATE LOGIN sql_test_user
WITH PASSWORD = 'SqlTest123!',
    CHECK_POLICY = ON,
    CHECK_EXPIRATION = ON;

-- Tüm login tiplerini listele
SELECT name, type_desc, is_disabled
FROM sys.server_principals
WHERE type IN ('S', 'U', 'G')
AND name NOT LIKE '##%'
AND name NOT LIKE 'NT %'
ORDER BY type_desc;
```

Sorgu sonucunda sistemdeki tüm login tipleri listelendi:

type_desc	Adet	Açıklama
SQL_LOGIN	5	SQL Server Authentication ile oluşturulan loginler
WINDOWS_GROUP	1	Windows grup hesabı
WINDOWS_LOGIN	1	Windows kullanıcı hesabı

Ardından rol bazlı erişim yönetimi uygulandı. sql_test_user kullanıcısına minimum yetki prensibi doğrultusunda tablo bazlı yetkiler atandı:

```
USE AdventureWorks2022;

CREATE USER sql_test_user FOR LOGIN sql_test_user;

-- Eriřim izinleri
GRANT SELECT ON Person.Person TO sql_test_user;
GRANT SELECT ON Sales.SalesOrderHeader TO sql_test_user;
GRANT UPDATE ON Sales.SalesOrderHeader TO sql_test_user;

-- Hassas tablolara erişim engeli
DENY SELECT ON HumanResources.Employee TO sql_test_user;
DENY SELECT ON HumanResources.EmployeePayHistory TO sql_test_user;
```

Doğrulama sorgusu 2 DENY ve 4 GRANT döndürdü. DENY, GRANT'tan önceliklidir — bir kullanıcı hem GRANT hem DENY almışsa DENY kazanır. Bu minimum yetki prensibi açısından kritik bir güvenlik katmanıdır.

Durum	Adet	Kapsam
GRANT	4	Person.Person (SELECT), SalesOrderHeader (SELECT, UPDATE), CONNECT
DENY	2	HumanResources.Employee, EmployeePayHistory

5. Veri Şifreleme

SQL Server Express Edition'da TDE desteklenmediğinden sütun bazlı şifreleme uygulandı. Bu yöntem belirli hassas kolonları şifreler ve Express Edition'da çalışır. Şifreleme zinciri şu şekilde oluşturuldu: Master Key → Sertifika → Simetrik Anahtar.

```
USE master;
GO

-- 1. Master Key oluştur
CREATE MASTER KEY ENCRYPTION BY PASSWORD = 'MasterKey123!';
GO

-- 2. Sertifika oluştur
CREATE CERTIFICATE TDE_Cert
WITH SUBJECT = 'AdventureWorks TDE Sertifikasi',
     EXPIRY_DATE = '2027-12-31';
GO

-- 3. Simetrik anahtar oluştur (AES_256)
CREATE SYMMETRIC KEY ColumnEncrypt_Key
WITH ALGORITHM = AES_256
ENCRYPTION BY CERTIFICATE TDE_Cert;
```

Test tablosu oluşturularak TC kimlik numaraları şifreli olarak eklendi. Anahtarsız okuma ile anahtarlı okuma karşılaştırıldı:

Durum	TCKimlik Görünümü
Anahtarsız (Şifreli)	0x0083D702FB3E2349A14ED3B07C9929... (anlamsız binary)
Anahtarlı (Çözülmüş)	12345678901, 98765432109, 11223344556 (okunabilir)

Anahtar olmadan TC kimlik numaraları tamamen okunamaz haldedir. Bu yöntem kredi kartı numarası, TC kimlik numarası gibi hassas verilerin korunmasında etkin biçimde kullanılmaktadır.

6. SQL Injection Testleri

SQL Injection, kullanıcı girişine kötü niyetli SQL kodu eklenerek veritabanının manipüle edilmesidir. Önce güvensiz sorgu yöntemi ile saldırı simüle edilmiş, ardından Stored Procedure ile korunma gösterilmiştir.

```
-- GÜVENSİZ YÖNTEM: SQL Injection'a açık
DECLARE @kullanici_girdisi NVARCHAR(100);
SET @kullanici_girdisi = 'Gail';
EXEC('SELECT * FROM Person.Person WHERE FirstName = ''' +
@kullanici_girdisi + ''');
-- SONUÇ: 8 satır (beklenen)

-- SQL INJECTION SALDIRISI
SET @kullanici_girdisi = ''' OR '1'='1';
EXEC('SELECT * FROM Person.Person WHERE FirstName = ''' +
@kullanici_girdisi + ''');
-- SONUÇ: 19.974 satır (TÜM VERİLER İFŞA OLDU!)
```

Normal sorguda 8 satır gelirken SQL Injection saldırısıyla 19.974 satır döndü ve tablodaki tüm veriler ifşa oldu. WHERE koşuluna eklenen OR 1=1 ifadesi koşulu her zaman TRUE yaptı.

```
-- GÜVENLİ YÖNTEM: Stored Procedure ile koruma
CREATE PROCEDURE sp_GuvenliKullaniciAra
    @kullanici_adi NVARCHAR(100)
AS
BEGIN
    SELECT BusinessEntityID, FirstName, LastName
    FROM Person.Person
    WHERE FirstName = @kullanici_adi;
END;
GO

-- Normal kullanım
EXEC sp_GuvenliKullaniciAra @kullanici_adi = 'Gail';
-- SONUÇ: 8 satır

-- Injection denemesi
EXEC sp_GuvenliKullaniciAra @kullanici_adi = ''' OR '1'='1';
-- SONUÇ: 0 satır - SALDIRI ENGELLENDİ!
```

Senaryo	Yöntem	Sonuç
Normal sorgu	Güvensiz EXEC	8 satır
Injection saldırısı	Güvensiz EXEC	19.974 satır - (Tehlikeli)
Normal sorgu	Stored Procedure	8 satır
Injection saldırısı	Stored Procedure	0 satır - (Engellendi)

Stored Procedure parametreyi doğrudan SQL koduna gömmek yerine ayrı bir değer olarak işler. Bu sayede saldırgan girişi SQL komutu olarak yorumlanamaz ve saldırı başarısız olur.

7. Audit Logları

SQL Server Audit özelliği kullanılarak kullanıcı aktiviteleri kayıt altına alındı. Audit, kim, ne zaman, hangi tabloda işlem yaptığını zaman damgasıyla birlikte loglar.

```
USE master;
GO

-- Server Audit oluştur
CREATE SERVER AUDIT AW_Audit
TO FILE (
    FILEPATH = '...\MSSQL\Backup\' ,
    MAXSIZE = 10 MB,
    MAX_FILES = 5
)
WITH (QUEUE_DELAY = 1000, ON_FAILURE = CONTINUE);
GO

ALTER SERVER AUDIT AW_Audit WITH (STATE = ON);
GO

-- Database Audit Specification oluştur
CREATE DATABASE AUDIT SPECIFICATION AW_DB_Audit
FOR SERVER AUDIT AW_Audit
ADD (SELECT ON Person.Person BY public),
ADD (INSERT ON Person.Person BY public),
ADD (UPDATE ON Sales.SalesOrderHeader BY public),
ADD (DELETE ON Sales.SalesOrderHeader BY public);
GO

ALTER DATABASE AUDIT SPECIFICATION AW_DB_Audit
WITH (STATE = ON);
```

Audit logları okunduğunda aşağıdaki kayıtlar tespit edildi:

Kod	Anlamı	Açıklama
UP	UPDATE	SalesOrderHeader güncelleme işlemleri (4 adet)
SL	SELECT	Person.Person okuma işlemi
AUSC	Audit Session	Audit oturumu başlatma kaydı

Tüm işlemler zaman damgası, kullanıcı adı ve işlem tipiyle birlikte kayıt altına alındı. Audit logları güvenlik ihlallerinin tespitinde ve yasal uyumluluk gereksinimlerinin karşılanmasında kritik öneme sahiptir.

8. Sonuç ve Değerlendirme

Bu projede AdventureWorks2022 veritabanı üzerinde kapsamlı güvenlik analizleri ve uygulamaları başarıyla gerçekleştirilmiştir.

Adım	Yapılan İşlem	Sonuç
1	Authentication modu kontrolü	SIMPLE'dan Mixed Mode'a geçildi
2	SQL Server Auth login oluşturma	5 SQL_LOGIN, 1 WINDOWS_GROUP, 1 WINDOWS_LOGIN
3	Rol bazlı erişim yönetimi	2 DENY, 4 GRANT atandı
4	Sütun bazlı şifreleme (AES-256)	Şifreli: 0x0083D702... / Çözülmüş: 12345678901
5	SQL Injection saldırısı	Güvensiz: 19.974 satır / Korumalı: 0 satır
6	SQL Server Audit	UP, SL, AUSE logları alındı

Veritabanı güvenliği çok katmanlı bir yapı gerektirir. Authentication ile erişim kontrolü, şifreleme ile veri gizliliği, SQL Injection korumasıyla uygulama güvenliği ve Audit loglarıyla izlenebilirlik bir arada sağlanmalıdır. Production ortamlarında TDE (Standard/Enterprise Edition), Row-Level Security ve Always Encrypted gibi ek güvenlik katmanları da uygulanmalıdır.